



CLIENT DELIVERABLE

SAOS Security Architecture v1.0

Systack Documentation

Table of Contents

SAOS Security Architecture — Enterprise Hardening

Overview

1. Multi-Factor Authentication (MFA)
2. Role-Based Access Control (RBAC)
3. Advanced Rate Limiting

Audit Trail

Remaining Security Priorities (Not Yet Built)

ROLE	COLOR	HEX
Headers, CTAs	Navy	 #001a2d
Navy Light	Navy Light	 #002845
Secondary accents	Teal	 #007da9
Primary buttons, links	Cyan	 #00a1db
Gradients	Cyan Bright	 #00c5e0
Backgrounds	Gray 50	 #f8fafc
Cards	Gray 100	 #f1f5f9
Borders	Gray 200	 #e2e8f0
Muted text	Gray 400	 #94a3b8
Body text	Gray 600	 #475569
Headings	Gray 800	 #1e293b
Success	Green	 #22c55e
Error	Red	 #ef4444
Accent highlights	Purple	 #8b5cf6

SAOS Security Architecture — Enterprise Hardening

Overview

SAOS Customer Portal (port 8768) has been hardened with enterprise-grade security controls. This document covers the three Priority 1 items from the Oracle security assessment.

1. Multi-Factor Authentication (MFA)

Implementation

- **Type:** TOTP (Time-based One-Time Password) — RFC 6238
- **Algorithm:** HMAC-SHA1, 6 digits, 30-second period
- **Compatible apps:** Google Authenticator, Authy, Microsoft Authenticator, 1Password, any standard TOTP app

API Endpoints

ENDPOINT	METHOD	AUTH REQUIRED	PURPOSE
/api/auth/mfa/setup	POST	Bearer token	Initialize MFA — returns secret + QR URI
/api/auth/mfa/verify	POST	Bearer token	Verify TOTP code and enable MFA — returns recovery codes
/api/auth/mfa/disable	POST	Bearer token	Disable MFA — requires PIN + current MFA code
/api/auth/mfa/status	GET	Bearer token	Check if MFA is enabled

Login Flow with MFA

1. Client sends `POST /api/auth/login` with `client_id` + `pin`
2. If MFA is enabled, server returns `{"mfa_required": true}` (HTTP 200)
3. Client sends login again with `client_id` + `pin` + `mfa_code`
4. Or use `recovery_code` instead of `mfa_code` for one-time bypass

Recovery Codes

- 8 one-time use recovery codes generated on MFA enable
- Each code is 16 hex characters
- Stored in `saos_clients.mfa_recovery_codes` (JSONB array)

- Consumed codes are removed from the array automatically

Security Notes

- MFA secret is stored in `saos_clients.mfa_secret` (base32 encoded)
- Login response excludes sensitive fields (`auth_pin`, `mfa_secret`, `mfa_recovery_codes`, `temp_pin`)
- MFA verification has its own rate limit: 5 attempts per 5 minutes

2. Role-Based Access Control (RBAC)

Default Roles

ROLE	DESCRIPTION	KEY PERMISSIONS
customer	Standard client	dashboard, tasks, chat, deliverables, docs
support	Support staff	All customer + <code>all_clients</code> (read across tenants)
billing	Billing access	dashboard, billing, docs
ops	Operations	dashboard, tasks, agents, provisioning, ops, <code>all_clients</code>
admin	Full admin	All permissions including admin, users, billing

Database Schema

```
-- saos_clients.role column (VARCHAR(20), default: 'customer')
-- saos_roles table:
CREATE TABLE saos_roles (
  role VARCHAR(20) PRIMARY KEY,
  description TEXT,
  permissions JSONB DEFAULT '{}'::jsonb,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

API Endpoints

ENDPOINT	METHOD	ROLE REQUIRED	PURPOSE
<code>/api/auth/roles</code>	GET	admin	List all roles + permissions
<code>/api/admin/client/<id>/role</code>	PUT	admin	Change a client's role
<code>/api/auth/permissions</code>	GET	any authenticated	Get current client's permissions

Decorators

```
@require_role('admin')      # Require specific role(s)
@require_permission('billing') # Require specific permission
```

Security Notes

- Role changes are logged to `audit_log`
- Access denied attempts are logged to `audit_log`
- All existing clients default to `customer` role
- Only `admin` role can change roles or list all roles

3. Advanced Rate Limiting

Per-Endpoint Configuration

ENDPOINT TYPE	MAX REQUESTS	WINDOW	APPLIED TO
<code>login</code>	5	5 min	<code>/api/auth/login</code>
<code>mfa_verify</code>	5	5 min	<code>/api/auth/mfa/verify</code>
<code>pin_reset</code>	3	1 hour	<code>/api/auth/forgot-pin</code>
<code>register</code>	5	1 hour	<code>/api/auth/register</code>
<code>api_general</code>	100	1 min	Default for all API endpoints
<code>api_write</code>	30	1 min	POST/PUT/DELETE endpoints
<code>webhook</code>	200	1 min	Webhook endpoints
<code>file_upload</code>	10	1 min	File upload endpoints

HTTP Headers

Rate-limited responses include: - `X-RateLimit-Limit` : Maximum requests allowed - `X-RateLimit-Remaining` : Remaining requests in window - `Retry-After` : Seconds until reset (on 429)

Implementation

```
@rate_limit('login')      # Apply specific rate limit
@rate_limit('api_write')   # Apply write rate limit
```

Audit Trail

All security events are logged to the `audit_log` table:

ACTION	WHEN
<code>login_success</code>	Successful login
<code>login_failed_*</code>	Failed login (with reason)
<code>login_mfa_required</code>	MFA challenge issued
<code>login_failed_bad_mfa</code>	Wrong MFA code
<code>login_failed_bad_recovery</code>	Wrong recovery code

ACTION	WHEN
mfa_setup_initiated	MFA setup started
mfa_enabled	MFA successfully enabled
mfa_disabled	MFA disabled
pin_changed	PIN changed
role_changed	Client role changed
access_denied_wrong_role	RBAC blocked access
access_denied_missing_permission	Permission denied
rate_limited_*	Rate limit hit
logout	User logged out

Remaining Security Priorities (Not Yet Built)

Priority 2 — Backup & Recovery

- ☐ Automated database backup verification
- ☐ Restore drill procedure
- ☐ Documented RPO/RTO

Priority 3 — Security Monitoring

- ☐ Failed login dashboard
- ☐ Authentication anomaly detection
- ☐ IP reputation monitoring

Priority 4 — Admin Console Hardening

- ☐ Audit export system
- ☐ Customer audit reports

Priority 5 — Compliance Package

- ☐ Security policy document
- ☐ Data retention policy
- ☐ Incident response procedures
- ☐ Trust center page